

MATRICE DES RÔLES & CONTRÔLE D'ACCÈS (RBAC)

Modèle de Sécurité, Cloisonnement des Données & Prévention Anti-IDOR • SI-LÉGAL

OBJECTIF DE LA MATRICE :

Garantir le respect du secret professionnel, interdire les élévations de privilèges (IDOR) et cloisonner les droits.

1. DÉFINITION DES 6 RÔLES DU SYSTÈME

ADMIN / SUPER_ADMIN Gestion des comptes, reset MDP, supervision technique et sécurité.	ASSOCIE (Partner) Direction : accès intégral à tous les dossiers, CA global et validation.	AVOCAT (Titulaire) Opérationnel : gestion exclusive de ses dossiers et dossiers assignés.
COLLABORATEUR Production : travail sur dossiers assignés, saisie des temps et actes.	COMPLIANCE_OFFICER Conformité : screening sanctions/PPE, scoring risque et fiches KYC.	SECRETARIAT Support : accueil, création préliminaire et facturation préparée.

2. MATRICE COMPLÈTE DES DROITS D'ACCÈS PAR MODULE

MODULE & ACTION MÉTIER	ADMIN	ASSOCIÉ	AVOCAT	COLLAB.	COMPLIANCE	SECRÉTARIAT
[MODULE 1] ADMINISTRATION SYSTÈME & SÉCURITÉ						
Création / Modification d'utilisateurs	OUI	NON	NON	NON	NON	NON
Réinitialisation mot de passe & 2FA	OUI	NON	NON	NON	NON	NON
Désactivation / Suppression de compte	OUI	NON	NON	NON	NON	NON
Consultation des logs d'erreurs BDD	OUI	Audit	NON	NON	Audit AML	NON
[MODULE 2] PROFIL CABINET & PARAMÉTRAGES						
Modification IBAN, SIRET, Coordonnées	OUI	OUI	NON	NON	NON	NON
Gestion modèles d'actes & domaines	OUI	OUI	OUI	Lecture	Lecture	Lecture
[MODULE 3] CONFORMITÉ & VIGILANCE AML / LCB-FT						
Lancement Screening Sanctions / PPE	OUI	OUI	OUI	OUI	OUI	NON
Validation score de risque & levée alerte	OUI	OUI	NON	NON	OUI	NON
Génération rapport audit Bâtonnier (PDF)	OUI	OUI	OUI	NON	OUI	NON
[MODULE 4] DOSSIERS, PIÈCES & AGENDA (ANTI-IDOR)						
Création d'un nouveau dossier	OUI	OUI	OUI	OUI	NON	OUI
Consultation pièces & actes du dossier	Tous	Tous	Assignés	Assignés	Pièces KYC	Pièces adm.
Suppression définitive de documents	OUI	OUI	Ses pièces	NON	NON	NON
Planning d'audiences & gestion des tâches	Tous	Tous	Ses dossiers	Ses tâches	NON	OUI
[MODULE 5] FACTURATION & HONORAIRES						
Saisie des temps & prestations	OUI	OUI	Ses temps	Ses temps	NON	Frais/Déb.
Émission & validation des factures	OUI	OUI	Ses dossiers	NON	NON	Émission
Dashboard financier & CA global cabinet	OUI	OUI	CA perso	NON	NON	NON

3. RÈGLES FONDAMENTALES DE PRÉVENTION ANTI-IDOR

Règle 1 : Cloisonnement Horizontal des Dossiers & Pièces

Un identifiant direct transmis dans l'URL (ex: GET /api/dossiers/1452 ou /api/documents/890) ne suffit JAMAIS pour autoriser l'accès. Le système valide automatiquement que l'utilisateur est ADMIN/ASSOCIÉ ou expressément désigné dans la liste des intervenants du dossier.

Règle 2 : Étanchéité Stricte des Données Financières

L'accès au Dashboard financier (/api/billing/dashboard) filtre dynamiquement les résultats : les associés visualisent le chiffre d'affaires consolidé du cabinet, tandis que les avocats collaborateurs ne visualisent que la rentabilité de leurs propres dossiers.

Règle 3 : Verrouillage des Actions d'Élévation de Privilèges

Toute tentative de réinitialisation de mot de passe tiers, de modification d'IBAN ou d'altération de rôles sans privilèges ADMIN/ASSOCIÉ lève immédiatement une exception AccessDeniedException (HTTP 403) et enregistre l'incident dans app_error_logs.

4. DIRECTIVES D'IMPLÉMENTATION SPRING SECURITY (@PreAuthorize)

```
// 1. Protection RBAC sur UserController
@PostMapping("/{id}/reset-password")
@PreAuthorize("hasAnyRole('ADMIN', 'SUPER_ADMIN')")
public ResponseEntity<String> resetPassword(@PathVariable Long id) { ... }

// 2. Protection Profil Cabinet (IBAN / SIRET) sur CabinetProfileController
@PutMapping
@PreAuthorize("hasAnyRole('ADMIN', 'SUPER_ADMIN', 'ASSOCIE')")
public ResponseEntity<CabinetProfileDTO> updateProfile(@Valid @RequestBody CabinetProfileDTO dto) { ... }

// 3. Protection Anti-IDOR sur les Pièces de Dossiers (DocumentController)
@DeleteMapping("/{id}")
@PreAuthorize("hasAnyRole('ADMIN', 'SUPER_ADMIN', 'ASSOCIE') or @securityUtils.isDocumentOwner(#id)")
public ResponseEntity<Void> deleteDocument(@PathVariable Long id) { ... }
```

ATTESTATION DE CONFORMITÉ & VALIDATION TECHNIQUE :

L'application stricte de cette matrice élimine les failles de sécurité critiques liées aux contrôles d'accès et protège les données sensibles des clients du cabinet d'avocats conformément aux règles ordinales et au RGPD.